Harran Üniversitesi · Mühendislik Fakültesi
Bilgisayar Mühendisliği ve Yazılım Mühendisliği Lisans Programları
YAZILIM GEÇERLEME VE SINAMA · 2026–2027 Güz Yarıyılı
Dersin Öğretim Üyesi: Dr. Öğr. Üyesi Harun ÇİĞ

Ödev 1 — Hata Zinciri, Test Seviyeleri ve Risk Tabanlı Test Planı

Yazılım Geçerleme ve Sınama · 2026–2027 Güz

1. Künye

Alan	Bilgi
Ödev	Ödev 1 (iki haftada bir verilen altı ödevin ilki) · 100 puan
Kapsanan haftalar	1–2: yazılım testinin temelleri; test süreci, test seviyeleri ve test çeşitleri
Veriliş	2. hafta Pazartesi, derste
Teslim	3. haftanın Pazar günü, saat 23.59, dersin teslim sayfasına
Ağırlık	Altı ödevin en düşüğü atılır, kalan beşi eşit sayılır: bu ödev başarı notunun **%2**'sidir
Çalışma biçimi	Bireysel
Teslim biçimi	Tek ZIP: `OgrenciNo_Odev01.zip`. İçinde yalnız rapor: `OgrenciNo_Odev01_Rapor.pdf`. Bu ödevde kod ve Maven projesi yoktur
Tahmini süre	6–8 saat

2. Öğrenme çıktıları

Bu ödevi bitiren öğrenci:

- gerçek bir arızayı insan hatası → hata → arıza zinciri ve kök nedeniyle çözümler, yedi test ilkesini somut bir üründe uygular (ISTQB CTFL v4.0.1 §1.2.3, §1.3.1);
- bir test senaryosunun test seviyesini ve test çeşidini (test türü) belirler, onaylama testini regresyon testinden ayırır (§2.2.1–2.2.3);
- ürün risklerini olasılık × etki ile seviyelendirir ve risk tabanlı bir test planı yazar (§5.1.1, §5.1.3, §5.2.1–5.2.4; ISO/IEC/IEEE 29119-3).

3. Malzeme ve bağlam

- **BiletKapısı Gereksinim Belgesi 2.0.1** (ders sayfasında): G-01…G-24 fonksiyonel, K-01…K-08 kalite gereksinimleri, §4 rezervasyon durum modeli, §7 taklit ödeme sağlayıcı, §8 Saat arayüzü, Ek A örnek veri. Belgeye kimlikle gönderme yapın: "G-22", "K-03", "§4.2".
- **H01 ve H02 ders notları:** terimler, bir hatanın arızaya dönüşmesinin dört koşulu (ulaşılabilirlik, enfeksiyon, yayılma, açığa çıkma), yedi ilke, beş test seviyesi, dört test çeşidi, onaylama ve regresyon testi, risk ve test planı.
- **Risk ölçeği (derste ilan edildi):** olasılık (O) ve etki (E) için 1 düşük, 2 orta, 3 yüksek. Seviye = O × E; 1–2 düşük, 3–4 orta, 6–9 yüksek. Eşit seviyede etkisi yüksek olan önce gelir.
- **Terimler:** TTB karşılıklarını kullanın: insan hatası (error), hata (defect), arıza (failure), kök neden (root cause), test çeşidi, onaylama testi. "Kusur", "işlevsel" ve "işlev dışı" kullanılmaz.
- G1'in olay özeti aşağıdadır. Araştırma yapmanız gerekmez; özette olmayan bir ayrıntı yazarsanız kaynağını verin.

G1 için olay özeti: Cloudflare, 2 Temmuz 2019

Cloudflare, milyonlarca web sitesinin trafiğini kendi sunucularından geçiren bir içerik dağıtım ve güvenlik şirketidir. Bu sunucularda çalışan web uygulaması güvenlik duvarı (WAF), gelen her HTTP isteğini düzenli ifadelerle (regex) yazılmış kurallara göre süzer.

2 Temmuz 2019'da saat 13.42'de (UTC) bir mühendis, siteler arası betik (XSS) saldırılarını yakalayan kurallarda küçük bir değişiklik yaptı. Yeni kurallar "benzetim" (simulate) kipindeydi: hiçbir isteği engellemeyecek, yalnız eşleşmeleri kaydedeceklerdi. Değişiklik otomatik bir süreçle, kademe olmadan bütün veri merkezlerine aynı anda dağıtıldı. Yeni kuralın düzenli ifadesi `.*(?:.*=.*)` parçasını içeriyordu. Bu kalıp bazı girdilerde **aşırı geri izleme** (catastrophic backtracking) yapar: motorun denemesi gereken eşleşme sayısı girdi uzadıkça çok hızlı büyür. Kural benzetim kipinde de çalıştığı için HTTP trafiğini işleyen işlemci çekirdekleri dünyanın her yerinde %100'e yakın yüke ulaştı ve ziyaretçiler `502 Bad Gateway` hatası aldı. 14.07'de WAF bütün dünyada kapatıldı, 14.09'da trafik normale döndü. Kesinti yaklaşık 27 dakika sürdü.

Şirketin olay raporu, olayı birlikte doğuran etkenleri sayar. Bunlardan altısı:

- **Etken 1.** Bir mühendis, aşırı geri izleme yapabilen bir düzenli ifade yazdı.
- **Etken 2.** Bir düzenli ifadenin aşırı işlemci kullanmasını önleyen koruma, birkaç hafta önce WAF'ın işlemci kullanımını azaltmak için yapılan bir yeniden düzenlemede (refactoring) yanlışlıkla kaldırılmıştı.
- **Etken 3.** Kullanılan düzenli ifade motorunun (PCRE) çalışma süresi için bir üst sınır güvencesi yoktu.
- **Etken 4.** Test kümesi kuralların doğru eşleşip eşleşmediğini sınıyordu; aşırı işlemci kullanımını fark edecek bir ölçümü yoktu.
- **Etken 5.** İşletim prosedürü, acil olmayan bir kural değişikliğinin kademeli dağıtım olmadan bütün dünyaya gönderilmesine izin veriyordu. Yazılım sürümleri ise önce yalnız çalışanların trafiğini taşıyan, sonra küçük bir müşteri grubunun, sonra daha geniş bir "kanarya" grubunun geçtiği veri merkezlerinde deneniyordu.
- **Etken 6.** Geri alma planı WAF'ın iki kez baştan derlenmesini gerektiriyordu; bu uzun sürdü.

Olaydan sonra şirket korumayı geri ekledi, 3.868 kuralın tamamını aşırı geri izleme için elle inceledi, test kümesine bütün kurallar için performans ölçümü eklemeyi, çalışma süresi güvencesi olan bir düzenli ifade motoruna geçmeyi ve kural değişikliklerini kademeli dağıtıma bağlamayı planladı.

Kaynak: J. Graham-Cumming, "Details of the Cloudflare outage on July 2, 2019", Cloudflare Blog, 12 Temmuz 2019. blog.cloudflare.com/details-of-the-cloudflare-outage-on-july-2-2019

4. Görevler

G1 — Hata zinciri: Cloudflare 2019 (20 puan)

- **G1.1 Zincir tablosu (8 puan).** Sütunlar: *insan hatası · hata · hatanın bulunduğu çalışma ürünü · hatanın girdiği zaman*. Olaydaki en az **iki ayrı** insan hatası–hata çiftini yazın. Tablonun altına **arızayı** bir cümleyle, gözlenebilir biçimde yazın: kim, neyi, nasıl gördü?
- **G1.2 Kök neden (4 puan).** Her insan hatası için bir kök neden yazın: insan bu hatayı neden yaptı ve hata neden fark edilmeden üretime ulaştı? "Mühendis dikkatsizdi" kök neden değildir. Ayrıca etken 3–6'yı ikiye ayırın: hatanın oluşmasına ya da kaçmasına yol açanlar (kök neden) ve arızanın zararını büyütenler.
- **G1.3 Dört koşul (3 puan).** Koruma haftalar önce kaldırılmıştı, ama o haftalarda arıza görülmedi. Dört koşulla açıklayın: 2 Temmuz'da hangi koşul ilk kez sağlandı? Benzetim kipi neden işe yaramadı?
- **G1.4 Hangi test yakalardı? (5 puan)** En az **iki** test önerin. Her biri için: *test ne yapar (girdi, beklenen sonuç, ölçülen büyüklük) · test seviyesi · test çeşidi · değişiklikle ilgisi (onaylama / regresyon / değil) · yakalayacağı hata · olaydaki test kümesi neden yakalamadı*. Önerilerden biri etken 2'deki kaldırılan korumayı hedeflesin. Son olarak bir cümleyle tartışın: kademeli dağıtım bir test midir, yoksa zararı sınırlayan bir önlem mi?

G2 — Test seviyesi × test çeşidi (20 puan)

Aşağıdaki on senaryonun her biri için bir tablo satırı yazın. Sütunlar: *No* · *Seviye* (bileşen, bileşen entegrasyon, sistem, sistem entegrasyon, kabul) · *Fonksiyonel mi?* (fonksiyonel ya da fonksiyonel olmayan; fonksiyonel olmayanda ISO/IEC 25010 karakteristiği) · *Kaynak* (kara kutu ya da beyaz kutu) · *Değişiklikle ilgili* (onaylama, regresyon ya da –) · *Gerekçe* (bir cümle). Bir etiketi tartışmalı buluyorsanız ikinci seçeneği gerekçesiyle yazın; iyi gerekçeli bir alternatif kabul edilir.

No	Test senaryosu
S-01	`IptalKurali` sınıfı tek başına, sabit saatle sınanır: kalan süre 86 400 saniyeyken iptale izin vermeli, 86 399 saniyeyken vermemelidir (G-22).
S-02	`FiyatKurali` sınıfının kaynak koduna bakılarak her `if` kararının hem doğru hem yanlış sonucunu çalıştıran testler yazılır; JaCoCo raporunda sınıfın dal kapsamı %100 olur.
S-03	`RezervasyonServisi` sabit saat, gerçek `IptalKurali` ve bellek içi H2 üzerindeki `RezervasyonDeposu` ile kurulur; `ONAYLANDI` bir rezervasyon iptal edilince depodan okunan durumun `IPTAL` olduğu doğrulanır.
S-04	Test uzmanı uygulamayı tarayıcıda açar, IŞIK GECESİ'ni arar, C12 koltuğunu seçer, `TOK-ONAY` ile öder ve rezervasyonun `ONAYLANDI` göründüğünü görür.
S-05	50 eşzamanlı sanal kullanıcı 10 dakika boyunca `GET /api/v1/etkinlikler` uç noktasını çağırır; p95 ≤ 400 ms ve hata oranı < %1 beklenir (K-01).
S-06	Oturum jetonu olmadan gönderilen `POST /api/v1/rezervasyonlar` isteğinin `401`, başka bir üyenin rezervasyonunu okuma isteğinin `403` aldığı denetlenir (K-03).
S-07	BiletKapısı'nın gerçek bir ödeme kuruluşunun test ortamına bağlandığı bir sürümde, kuruluş zaman aşımı döndürünce rezervasyonun `BEKLEMEDE` kaldığı ve koltukların kaybolmadığı doğrulanır (K-07).
S-08	Bir öğrenci kulübünün üç yöneticisi, yayına almadan önce kendi konserlerinin satış akışını hazırlanmış bir ortamda baştan sona dener ve "işimizi görüyor" formunu imzalar.
S-09	HR-007 ("tam 1440 dakika kala iptal reddediliyor") düzeltildikten sonra, hatayı bulan bileşen testi değiştirilmeden yeniden koşulur ve geçer.
S-10	HR-007 düzeltmesi ana dala birleştirilince CI, düzeltmenin dokunmadığı `FiyatKurali` ve `KampanyaKurali` sınıflarının mevcut bütün bileşen testlerini yeniden koşar.

Biçim örneği (puanlanmaz): *S-00 · Otomatik bir denetim, koltuk seçim ekranındaki her koltuk düğmesinin erişilebilir adını ve 4,5:1 metin kontrastını sınar (K-06) → sistem · fonksiyonel olmayan: etkileşim yeteneği (erişilebilirlik) · kara kutu · – · çalışan ekranın tamamı sınanıyor; eşikler K-06'nın kabul kriterinden geliyor.*

G3 — Üç test ilkesi (15 puan)

Yedi test ilkesinden üçünü seçin. Her ilke için (ilke başına 5 puan):

- ilkenin resmî Türkçe adı ve bir cümlelik anlamı (1 puan);
- BiletKapısı'ndan somut bir örnek: bir G-xx ya da K-xx kimliği ve bir sayı ya da değer içersin (2 puan);
- bu ilke yüzünden test ekibinin bu üründe **farklı yapacağı** bir şey: bir karar ya da eylem (2 puan).

Kısıtlar: Ders notundaki örnekleri (200 koltukta 85 milyar seçim, CrowdStrike, Ariane) kullanmayın. Üç ilkeden en az biri 4., 5. ya da 7. ilke olsun. Her ilke en çok 120 kelime.

G4 — Risk analizi ve risk matrisi (20 puan)

BiletKapısı için **sekiz ürün riski** belirleyin.

- **G4.1 Risk kaydı (10 puan).** Sütunlar: *R-xx* · *risk* ("… olabilir; bu durumda …" kalıbıyla olası arıza ve sonucu) · *ilgili gereksinim* (G-xx, K-xx ya da §) · *O* · *E* · *O ve E'nin gerekçesi* (bir cümle) · *seviye* · *düzey*.
- **G4.2 Risk matrisi (3 puan).** 3 × 3 bir tablo: satırlar etki 3 → 1, sütunlar olasılık 1 → 3. Her hücreye oradaki risk kimliklerini yazın.
- **G4.3 Test önceliği (3 puan).** Riskleri test önceliğine göre sıralayın: seviye azalan; eşit seviyede etkisi yüksek olan önce; o da eşitse kendi gerekçeniz. Eşitlik kuralını nerede uyguladığınızı yazın.
- **G4.4 Risk yanıtı (4 puan).** Her risk için önerilen test: *seviye + çeşit + ne sınanacak* (somut değerlerle, ör. "899. ve 900. saniye"). Yüksek riskler için en az iki farklı test ya da iki seviye; düşük riskler için hafif bir yanıt (tek bir duman testi, kısa bir keşif turu) yeterlidir.

Kısıtlar: Yalnız ürün riski yazın; proje riskleri G5'e gider. Derste işlenen dört ürün riskinden (G-12 çift satış, G-22 iptal sınırı, G-06 "istanbul" araması, K-01 performans) en çok ikisini kullanabilirsiniz. Sekiz riskin en az ikisi bir kalite gereksinimine (K-xx), en az biri §4 durum modeline dayansın.

Biçim örneği (puanlanmaz; derste işlenen G-22 riskidir, kullanırsanız iki ders riski hakkınızdan biri sayılır): *R-00 · Tam 24 saat kala iptal reddedilebilir; bu durumda üye parasını geri alamaz · G-22 · O 3 · E 2 · sınır karşılaştırması hatası çok yaygın; üye para kaybeder ama sistem çalışır · 6 · yüksek.*

G5 — Risk tabanlı mini test planı (20 puan)

Test nesnesi: BiletKapısı'nın rezervasyon – ödeme – iptal akışı (G-11…G-24, §4, §7 ve ilgili K-02, K-03, K-07). En çok **iki sayfalık** bir test planı yazın. Başlıklar CTFL v4.0.1 §5.1.1'deki test planı içeriğini ve ISO/IEC/IEEE 29119-3'ün test planı belgesini izler:

Başlık	En az ne yazılır?	29119-3 karşılığı
1. Bağlam ve kapsam	Test nesnesi, 2–3 test hedefi, test esası; en az 3'er madde kapsam içi ve gerekçeli kapsam dışı (belge §1.2 ile tutarlı)	Context of testing: test items, test scope
2. Varsayımlar ve kısıtlar	En az ikişer madde	Assumptions and constraints
3. Paydaşlar ve iletişim	Kim, hangi rolde, neyi kime, hangi kanalla bildirir	Stakeholders; testing communication
4. Risk kaydı	G4'ten bu kapsama giren ürün riskleri (kimlikle) ve en az **iki proje riski** (O, E, seviye, azaltma önlemi)	Risk register
5. Test yaklaşımı	Seviyeler ve çeşitler; her **yüksek** riskin hangi seviye ve çeşitle ele alındığı; test bağımsızlığı; onaylama ve regresyon testinin ne zaman koşulduğu	Test strategy
6. Kriterler	En az 3 giriş ve 3 çıkış kriteri (ölçülebilir); birer askıya alma (koşumu geçici olarak durduran koşul) ve sürdürme (koşumu yeniden başlatan koşul) kriteri	Test completion criteria; suspension and resumption criteria
7. Test verisi ve ortamı	Saat, veritabanı, ödeme sağlayıcı, örnek veri	Test data and test environment requirements
8. Çalışma ürünleri ve metrikler	En az 3 test çalışma ürünü ve 3 metrik	Test deliverables; metrics
9. Roller, efor ve takvim	Kim ne yapar; kaba efor (kişi-saat); haftalara göre takvim	Staffing; activities and estimates; schedule

> **Ölçülebilir kriter:** "Testler büyük ölçüde geçti" ölçülemez. "Seviyesi 6–9 olan her risk için planlanan testlerin hepsi koşuldu ve geçti" ölçülebilir: bir başkası aynı veriye bakıp aynı kararı verir.

5. Teslim ve değerlendirme

Rapor şablonu

Rapor bir kelime işlemciyle hazırlanır (taranmış el yazısı kabul edilmez); A4, 11 punto (tablolarda 9–10 punto olabilir), kapak hariç en çok 10 sayfa. Başlıklar:

- Kapak: ad soyad, öğrenci numarası, ödev numarası, teslim tarihi
- 1. G1 — Hata zinciri (G1.1–G1.4)
- 2. G2 — Seviye × çeşit tablosu
- 3. G3 — Üç test ilkesi
- 4. G4 — Risk kaydı, risk matrisi, öncelik ve risk yanıtı
- 5. G5 — Test planı (dokuz başlık)
- 6. YZ beyanı (zorunlu)
- 7. Kaynaklar (özet ve gereksinim belgesi dışında kaynak kullandıysanız)

Otomatik ön koşul: Bu ödevde kod yoktur, dolayısıyla otomatik derleme denetimi de yoktur. Teslim tek ZIP ve içinde metni seçilebilir tek PDF olmalıdır.

Değerlendirme ölçütleri

Görev	Ölçüt	Puan
G1.1	İki insan hatası–hata çifti doğru ayrılmış; çalışma ürünü ve zaman doğru; arıza gözlenebilir yazılmış	8
G1.2	Kök neden insan hatasından ayrılmış; etken 3–6 kök neden ve zararı büyüten etken olarak ayrılmış	4
G1.3	Dört koşul olaya doğru uygulanmış; benzetim kipinin neden korumadığı açıklanmış	3
G1.4	İki test: seviye, çeşit, değişiklik ilişkisi ve neden kaçtığı doğru; kademeli dağıtım tartışılmış	5
G2	On senaryo × dört etiket; satır başına 2 puan (her yanlış etiket −0,5)	20
G3	Üç ilke × (anlam 1 + somut örnek 2 + eylem 2)	15
G4.1	Sekiz ürün riski; arıza kalıbında; gerekçeli O ve E; doğru seviye ve düzey; kısıtlar sağlanmış	10
G4.2	Risk matrisi risk kaydıyla tutarlı	3
G4.3	Öncelik sırası ve eşitlik kuralı doğru	3
G4.4	Her riske seviye + çeşit + somut değerli test; yüksek risklere iki test	4
G5	Dokuz başlığın tamamı; iki sayfa sınırı	3
G5	Kapsam içi ve kapsam dışı belgeyle tutarlı ve gerekçeli	3
G5	Yaklaşım: her yüksek risk bir seviye ve çeşitle eşlenmiş; onaylama ve regresyon testi yerinde	5
G5	Ölçülebilir giriş, çıkış, askıya alma ve sürdürme kriterleri	4
G5	Proje riskleri, test verisi ve ortamı, roller ve takvim	5
Tümü	TTB terimleri; kimlikle gönderme; okunur tablolar ve sayfa sınırı; kaynak gösterimi	5
Toplam		**100**

6. Kurallar

- **Geç teslim:** Her gün için %20 düşülür; üç günden sonra teslim kabul edilmez ve not 0 olur.
- **Yapay zekâ:** YZ araçları serbesttir, ama her teslimde **YZ beyanı** bölümü zorunludur: hangi aracı, ne için kullandınız ve neyi kendiniz doğruladınız? Öğretim üyesi herhangi bir teslimi 5 dakikalık sözlü savunmaya çağırabilir. Beyanı olmayan ya da savunulamayan teslim 0 alır.
- **Kopya:** Kopya teslim 0 alır; ayrıca yönetmelik hükümleri uygulanır.
- **Sorular:** Ders sonrası görüşme saati (Pazartesi 11.30–12.00) ya da e-posta: haruncig@harran.edu.tr.